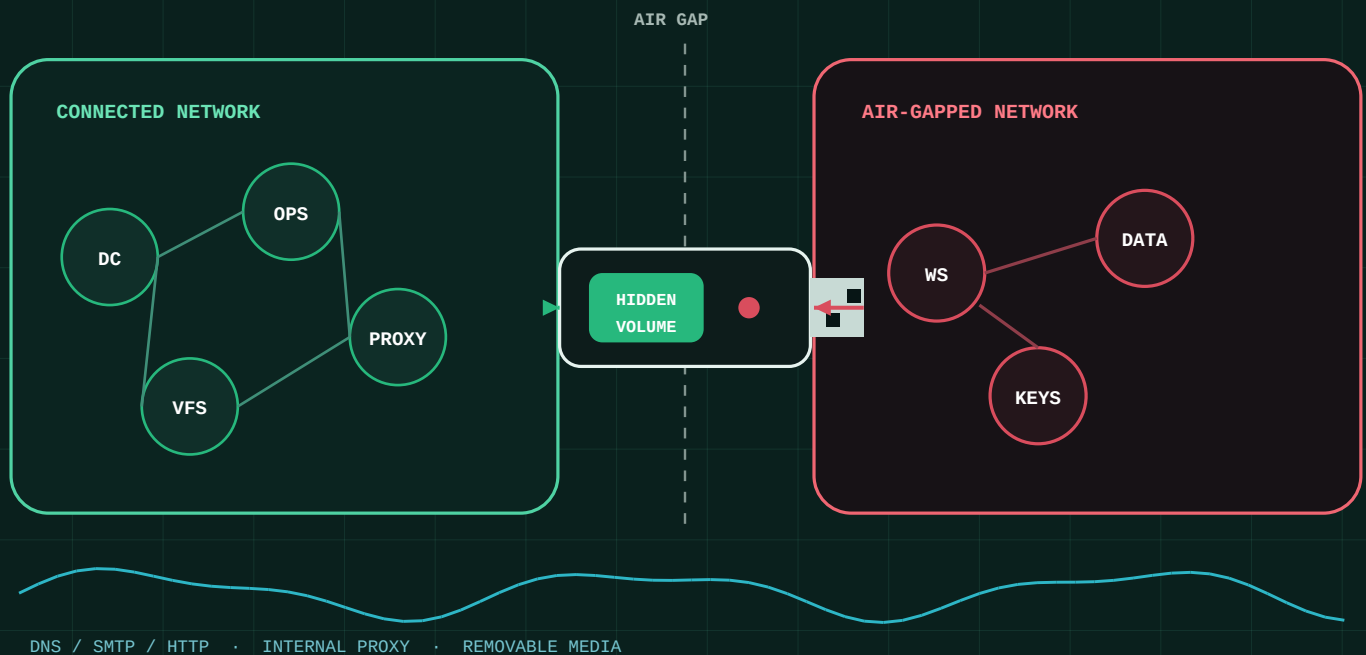




ProjectSauron / Strider

Air-Gap Espionage Platform

Technical Case Study - Customized Implants, Hidden USB Storage and Memory-Only Espionage

No reusable indicators. No visible partition. No obvious path out.

1. Incident at a glance

ProjectSauron was a long-running Windows cyber-espionage platform publicly exposed in 2016 after years of activity. Kaspersky described operations dating back to at least June 2011; Symantec independently tracked the actor as **Strider** and the modular malware platform as **Remsec**.

ACTIVITY WINDOW

At least 2011-2016 in public reporting.

PRIMARY PURPOSE

Long-term intelligence collection and cyber-espionage.

PLATFORMS

Windows x86 and x64 systems observed.

INITIAL ACCESS

Publicly unresolved.

CORE ARCHITECTURE

Modified Lua runtime, encrypted VFS and task-specific plugins.

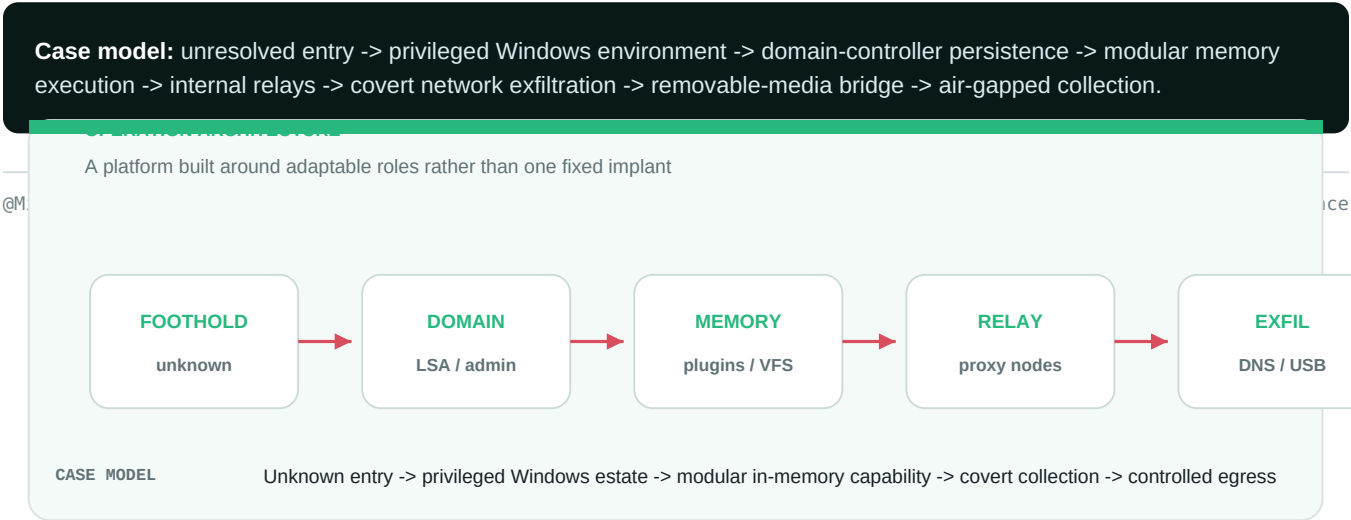
SIGNATURE CAPABILITY

Covert transfer across air-gapped networks using specially prepared USB media.

Core distinction: ProjectSauron should not be reduced to "USB malware." The public evidence describes a broad espionage architecture spanning authentication processes, memory-resident execution, internal relays, multiple network protocols, removable media and target-specific operational security.

Scope and confidence

Claim class	Treatment in this report
Confirmed	Vendor-observed behaviors such as password-filter persistence, modular plugins, DNS use, internal relays, removable-media tooling and victim-specific customization.
Strongly supported	ProjectSauron/Strider was optimized for low-repeatability espionage rather than noisy mass deployment.
Unknown	Initial infection vector, complete victim set, full operator structure and whether an undisclosed exploit was used in rare entry scenarios.



TIMELINE

2. 2011-2016: years below the radar

June 2011
Earliest activity in Kaspersky reconstruction. Symantec separately tracked Strider activity from at least October 2011.

2011-2015
Long-lived selective espionage. The actor maintained victim-specific implants, infrastructure and tasking across carefully chosen organizations.

September 2015
Anomalous traffic exposes a foothold. Kaspersky investigation identifies a suspicious library loaded on a Windows domain controller and registered as a password filter.

2015-2016
Platform reconstruction. Follow-on analysis reveals modular memory execution, custom virtual filesystems, multiple transports, removable-media tooling and internal relay capability.

April 2016
Observed campaign window continues. Kaspersky's public reconstruction places activity through approximately April 2016.

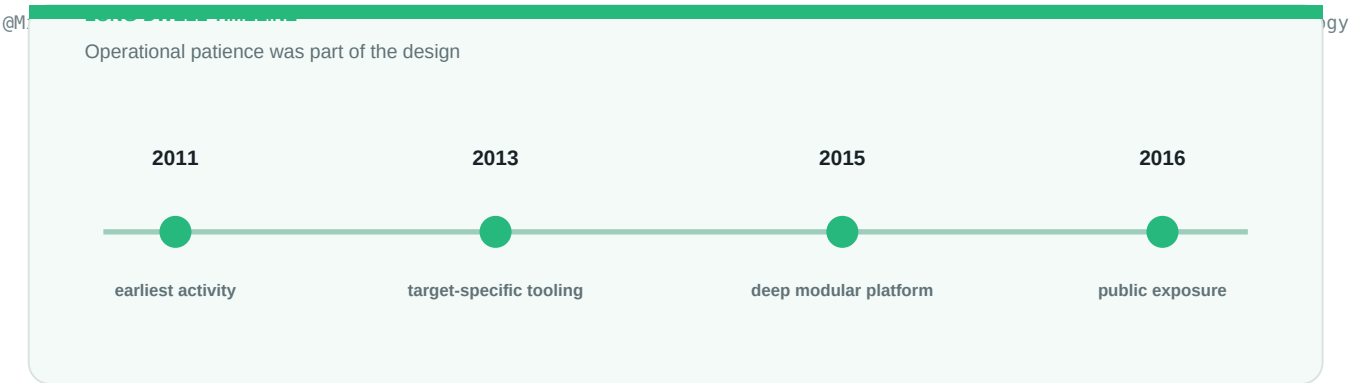
August 2016
Public disclosure. Kaspersky publishes ProjectSauron; Symantec independently publishes its Strider / Remsec findings.

Why the timeline matters: the operation survived for years while touching domain controllers, administrative deployment paths, removable media and sensitive communications infrastructure. Longevity came from minimizing repeatable artifacts and distributing capability across multiple trust layers.

Terminology discipline

Label	Use in this study
ProjectSauron	Kaspersky name for the threat actor / espionage platform; public usage can refer to both group and malware platform context.
Strider	Symantec and MITRE group label for the actor associated with Remsec.
Remsec	Symantec / MITRE software label for the modular backdoor and related components.

Method rule: unknown entry remains unknown. A polished invented initial-access story would make the report less accurate, not more complete.



3. High-value targets and the intelligence objective

Public victim telemetry points to selective espionage against organizations central to state functions, strategic communications and sensitive infrastructure.

KASPERSKY VISIBILITY

More than 30 infected organizations were reported across Russia, Iran, Rwanda and possibly Italian-speaking countries. Reported sectors included government, scientific research, military, telecommunications and finance.

SYMANTEC VISIBILITY

Symantec reported evidence on 36 computers across seven organizations, including targets in Russia, an airline in China, an organization in Sweden and an embassy in Belgium.

Do not merge these datasets. They reflect different products, customers, collection windows and investigation scopes.

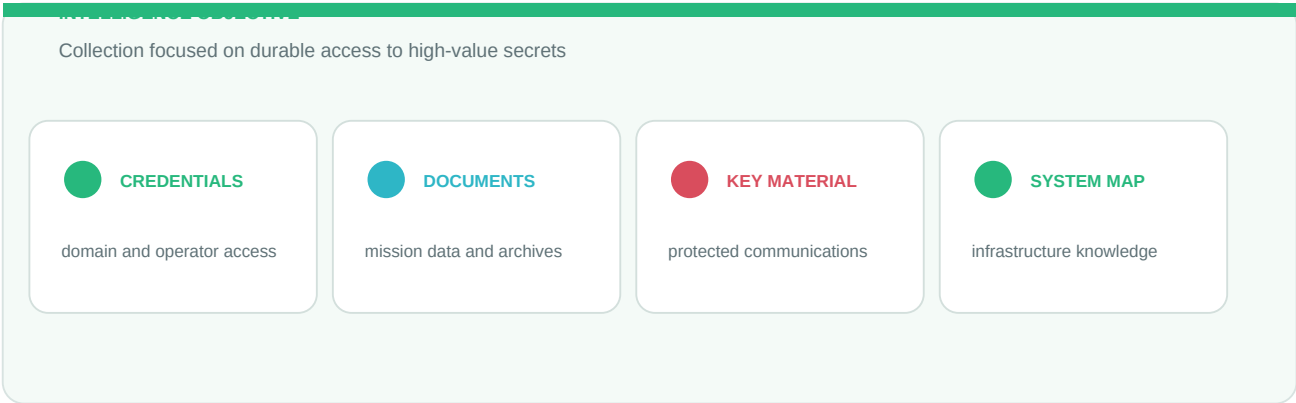
Focus on secure communications

Kaspersky reported strong interest in communication-encryption software used by government organizations. Collection included encryption keys, configuration files and network information associated with key-management or secure-communications infrastructure.

The strategic target was not merely a document. Authentication flows, encryption material and communication infrastructure can expose identities, relationships, message paths and future collection opportunities.

Critical-infrastructure nuance

Some affected organizations could be classified as critical infrastructure, but Kaspersky did not report ProjectSauron operating inside SCADA networks or targeting specific industrial control systems. The case is better understood as strategic espionage than as an ICS sabotage operation.



4. A platform, not a single implant

ProjectSauron combined loaders, backdoors, a modified Lua runtime, encrypted containers, virtual filesystems and specialized plugins. The important design choice was separation: persistence, orchestration and task-specific capability did not need to live in one stable binary.

Persistent foothold

Small stable component retains access in a privileged trust position.

Encrypted VFS

Configuration, scripts and plugin material remain packaged and concealed.

Lua orchestration

A modified runtime controls high-level task sequencing.

Plugin execution

Collection, discovery, transport and exfiltration capability appears only when required.

Why modularity mattered

Kaspersky documented more than 50 plugin types. Symantec likewise described executable blobs and Lua modules delivered as a modular framework. A defender could recover one component and still fail to reconstruct the platform if the surrounding trust path and runtime state were ignored.

DISK VIEW

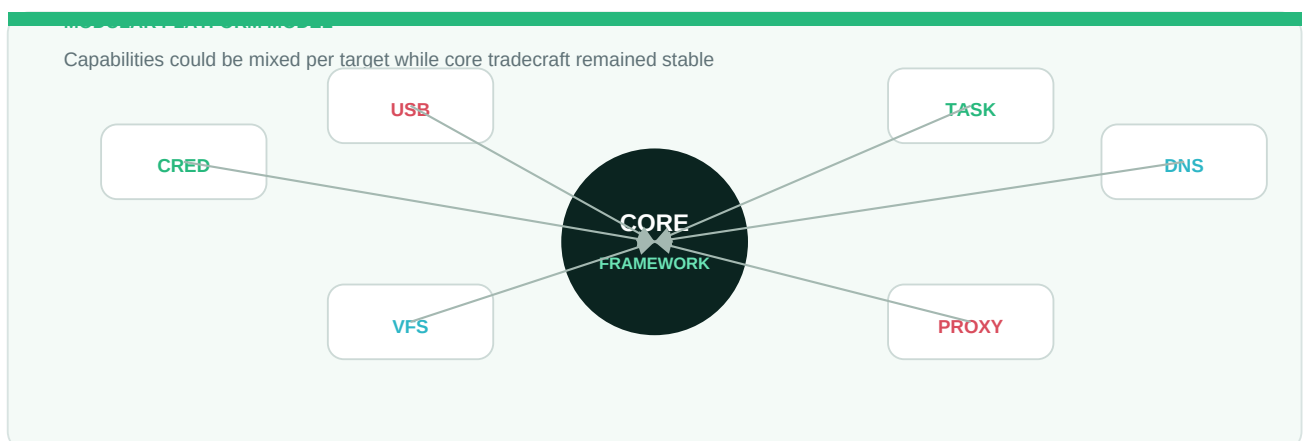
Outer containers, loaders and persistent modules may be present, but not every operational capability has to exist as a durable file.

RUNTIME VIEW

Decrypted configuration, loaded plugins, in-memory scripts and active network tasking can reveal far more than static filesystem triage.

Detection implication: architecture-oriented hunting asks which process owns the long-lived trust position, which modules appear only after tasking, where state is stored, which host becomes a relay and whether removable-media geometry contradicts the visible filesystem.

Analytical model: persistence is the anchor; orchestration is the control plane; plugins are disposable capability.



5. Domain controllers as credential collection points

One of ProjectSauron's most strategically powerful techniques was persistence through the Windows authentication stack.

Trust conversion: legitimate authentication extension -> privileged code in a security-sensitive process -> plaintext credential visibility -> broader network leverage.

Password-filter persistence

Kaspersky reported that ProjectSauron could register a persistence module on domain controllers as a Windows LSA password filter. Password filters are legitimate mechanisms used to enforce password policies. The malicious module abused that trust position to observe credentials when users logged on or changed passwords.

WHY IT IS HIGH-VALUE

- Domain controllers naturally process privileged identities.
- The operating system must handle password material before irreversible hashing.
- Long-lived access can avoid repeated noisy credential-dumping operations.

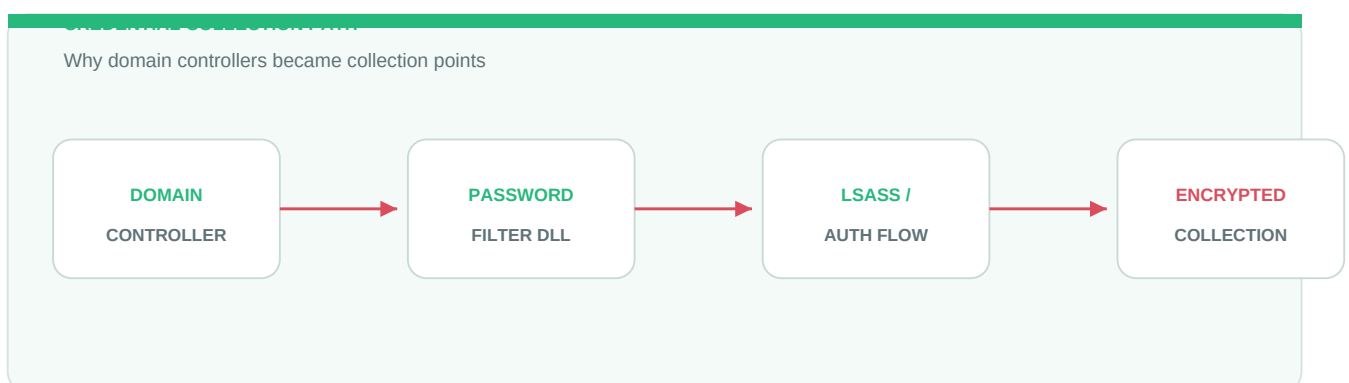
WHY IT CAN BE OVERLOOKED

- Authentication extensions are expected to be privileged.
- Security tooling may focus on database access rather than extension registration.
- A stable module can blend into a long-lived server baseline.

Defensive choke point

Password-filter and Security Support Provider registration should be governed like domain-admin membership or production signing keys: rare changes, explicit ownership, allowlisted code, peer approval and immediate review when module inventory changes.

Hunting question: why is an unapproved DLL loaded into LSASS on a domain controller, and what administrative event caused it to appear?



6. Encrypted VFS and ephemeral capability

The combination of a modified Lua engine, encrypted virtual filesystem and memory-only modules gave operators a flexible control plane while reducing conventional file-based evidence.

Layer	Observed role
Storage	VFS encrypted with RC4 or Salsa20 depending on platform/version and compressed with zlib.
Execution	Precompiled Lua scripts controlled task flow through an embedded, modified runtime.
Customization	The embedded Lua interpreter was modified, including UTF-16 handling for strings and variable names.
Plugin model	DLL-like plugins exposed console-style behavior and could be chained by the orchestration layer.

1 · Foothold

Stable component retains access.

2 · Tasking

Operator selects a capability only when needed.

3 · Memory load

Plugin appears in executable memory.

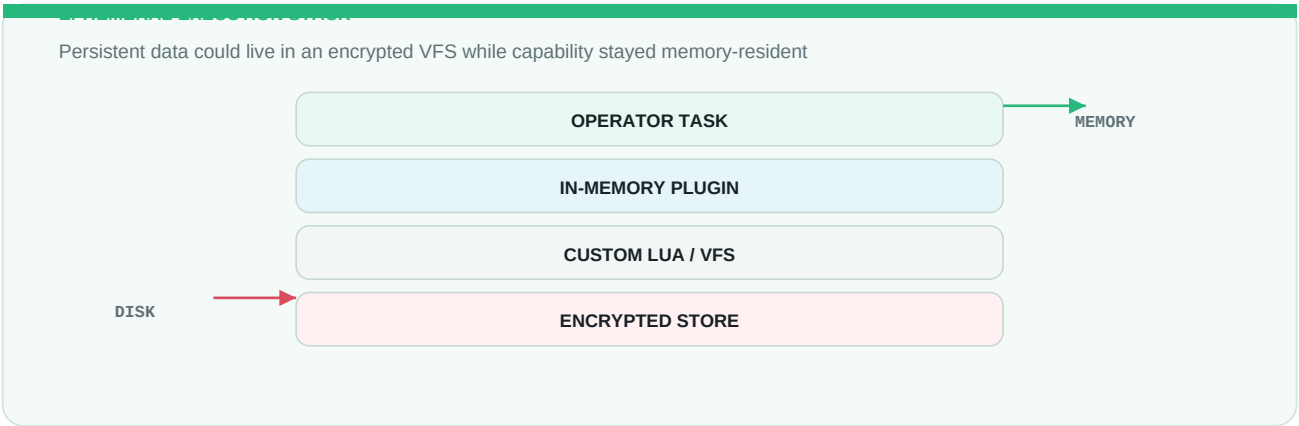
4 · Disappear

Capability may vanish after reboot or task completion.

Forensic consequence

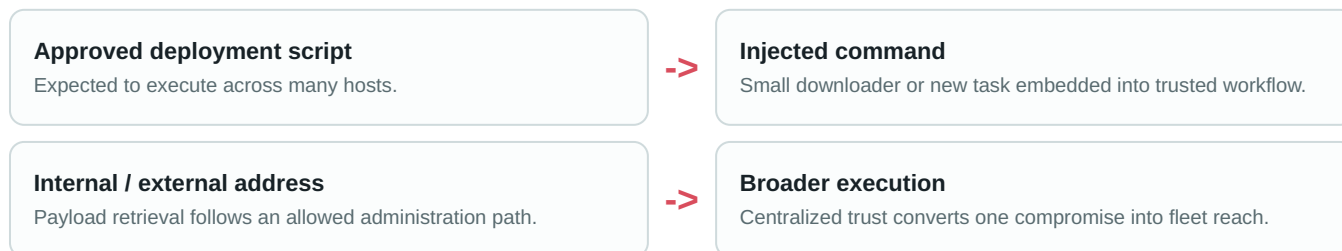
A clean disk is not proof of a clean host. Memory capture, loaded-module enumeration, executable-memory telemetry, handle inspection and network-to-process correlation may be the only way to reconstruct transient capability.

Forensic priority: when an encrypted container is present, acquisition of process memory can expose decrypted configuration, runtime state, task sequencing and plugins that the on-disk artifact intentionally conceals.



7. Trusted administration as an execution path

Kaspersky reported cases where ProjectSauron modules were deployed by modifying scripts that administrators already used to distribute legitimate software updates inside the target network.



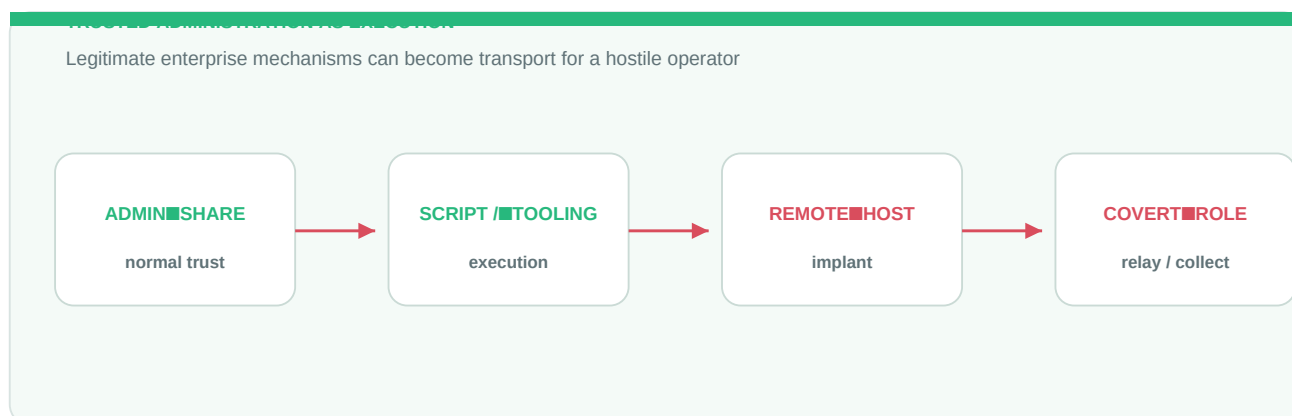
Why this is strategically effective

- The deployment channel already has administrative reach.
- Execution occurs under identities expected to install software.
- Network routes to update servers are often pre-authorized.
- Blue teams may suppress alerts from approved distribution systems.
- Script changes can look like ordinary operations unless provenance is enforced.
- One modified workflow can cross multiple segmentation boundaries.

Dormant listeners and internal relay nodes

ProjectSauron did not require every compromised server to communicate directly with the Internet. Some implants could remain dormant and wait for specific wake-up traffic. Where domain controllers lacked Internet access, other systems with both internal and external connectivity could function as relay nodes.

Behavioral invariant: even if the external infrastructure is unique to one victim, the role change of an internal server is observable. A web, proxy or update server should not suddenly relay opaque traffic between sensitive segments and the Internet.



8. Multi-protocol command, data and DNS signaling

ProjectSauron / Remsec supported several network mechanisms rather than depending on one conspicuous C2 protocol.

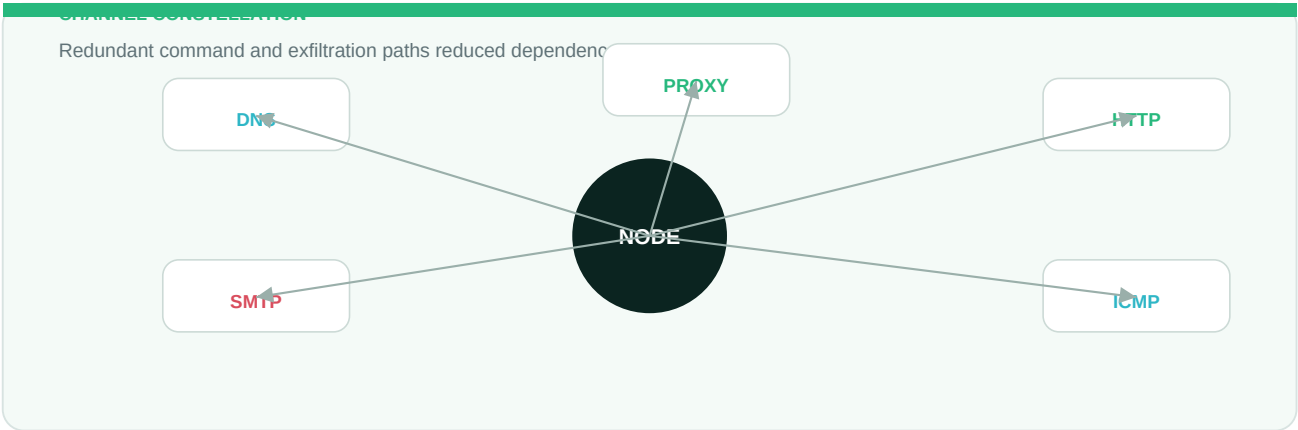
Channel	Operational value	Defensive angle
HTTP / HTTPS	Conventional web command and transfer.	Process-to-destination correlation and proxy logs.
SMTP	Transfer through email-like infrastructure.	Unexpected SMTP clients and attachment behavior.
DNS	Metadata exfiltration and operation-progress signaling.	Rare domains, entropy, cadence and host role.
ICMP	Alternate transport or wake-up behavior.	Payload-bearing ICMP and unusual endpoint participation.
TCP / UDP	Custom listeners and backdoor transports.	Unexpected raw sockets, listeners and packet capture.
Named pipes	Local or internal command paths.	Rare pipe names, unusual creators and cross-process access.

Low-bandwidth DNS tradecraft

Kaspersky documented a DNS exfiltration tool and a separate use of DNS for real-time operation-status reporting. Rather than bulk tunneling, the actor could encode small amounts of target metadata or signal operational milestones through target-specific subdomains.

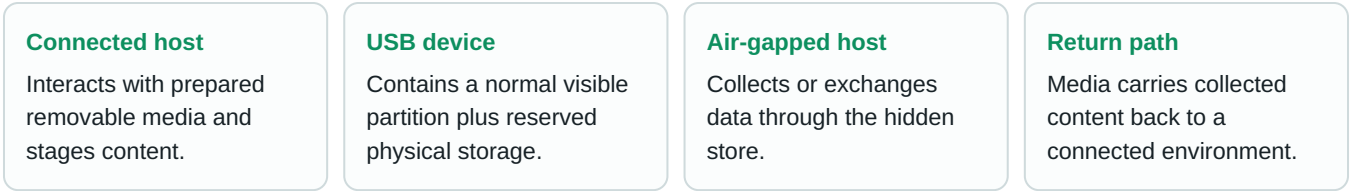
Better than "detect DNS tunnels": track first-seen domains queried only by sensitive servers; high-entropy labels at low volume; query timing immediately after privileged configuration changes; and process-to-query relationships that contradict the server's historical role.

Original hypothesis: milestone signaling may be more detectable than bulk exfiltration because one unusual query immediately after a privileged change can carry more investigative meaning than thousands of generic requests.



9. The removable-media bridge

ProjectSauron's most distinctive capability was moving information between Internet-connected and isolated environments using specially prepared USB media.



What the public evidence proves

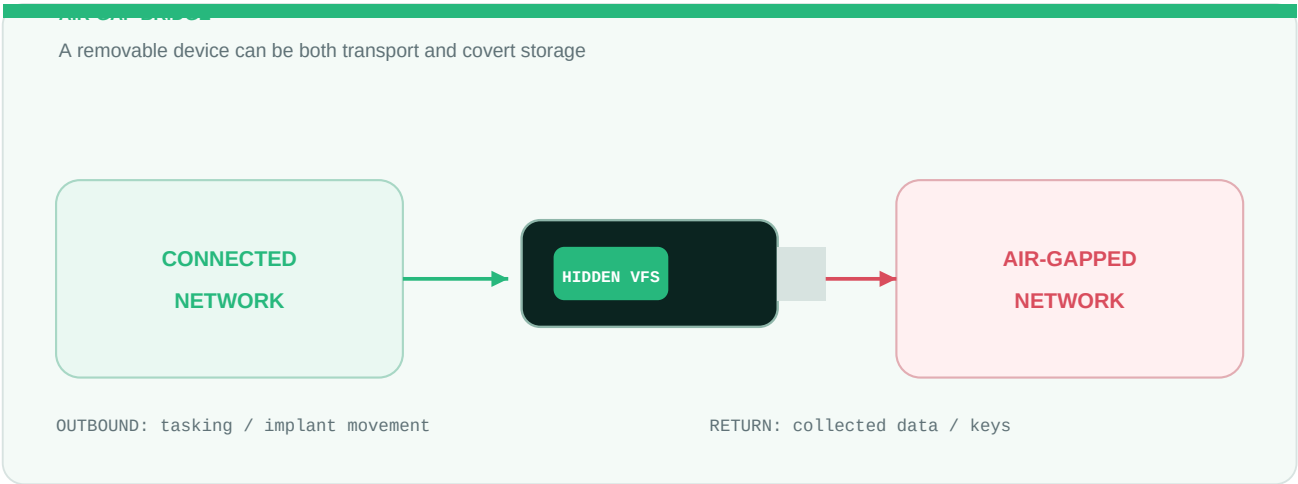
Kaspersky documented a toolkit module designed for hidden data transfer and cases in which air-gapped networks were penetrated. The USB was formatted so that the normal partition did not consume the full physical device; reserved sectors remained available for a custom encrypted structure.

Important boundary: the hidden-storage mechanism explains covert data transfer. It does *not* prove how code first executed on an air-gapped host. Kaspersky explicitly noted that another mechanism would be required for initial control, and no zero-day was identified in the analyzed material.

Security implication

An air gap removes direct network connectivity; it does not remove trust in physical media, transfer procedures or human movement. In this model, the removable device becomes a transport layer that crosses the segmentation boundary by design.

Boundary shift: network isolation -> media trust -> human-carried transport -> hidden storage -> delayed exfiltration.



10. Hidden storage beyond the visible partition

Kaspersky's technical analysis of the MyTrampoline component describes direct inspection of the physical disk layout when removable media arrives. The module looked immediately after the first partition recognized by the operating system for a specific magic value identifying a custom shadow filesystem.

LOCATION

Physical sectors after the normal OS-visible partition.

RECOGNITION

Custom magic value and private format rather than a Windows-recognized filesystem.

LOGICAL DESIGN

Separate areas for data written out and data brought back in.

PROTECTION

Cryptographic protection around stored / transferred content.

Why ordinary DLP can miss it

Endpoint controls often reason about mounted files, known device IDs and filesystem events. The same legitimate USB device can still expose additional addressable sectors that the normal OS never presents as files. Blocking unknown devices alone therefore does not solve the problem if already-trusted media is abused.

Detection invariant: physical capacity != visible partition geometry. If a removable disk reports more addressable storage than the mounted partition consumes, the gap is a forensic object worth examining.

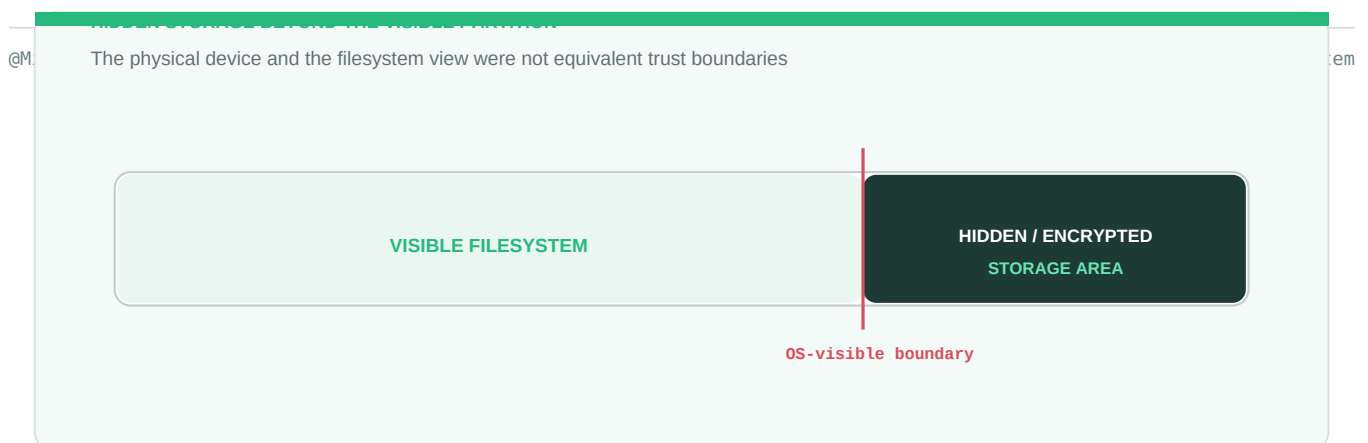
MyTrampoline's two-way model

The shadow filesystem supported bidirectional movement: local staging content could be written into one hidden area, while content from the opposite side could be extracted later into local storage and removed from the media.

```
connected side -> hidden outbound area -> air-gapped side
air-gapped collection -> hidden return area -> connected side -> remote repository / C2
```

Forensic response

Acquire the entire block device, not only files copied from the mounted volume. Partition-table review, raw-sector inspection and entropy analysis can reveal hidden storage that normal filesystem triage completely omits.



11. Credentials, documents and encryption infrastructure

ProjectSauron combined broad collection capability with a strategically focused interest in authentication and secure communications.

CREDENTIALS

Password-filter persistence created opportunities to capture plaintext credentials as authentication events occurred.

USER ACTIVITY

Remsec modules included keylogging and conventional file-stealing capability.

ENCRYPTION ECOSYSTEM

Kaspersky reported collection of encryption keys, configuration files and IP addresses related to custom network-encryption products used by government targets.

REMOVABLE MEDIA

Dedicated components collected documents from inserted USB storage.

Stealing a key or configuration file can be more valuable than stealing one document: it may unlock future communications, reveal trust relationships or expose the topology of secure messaging infrastructure.

Detection opportunities

- Monitor unusual access to key stores and configuration directories.
- Correlate removable-media insertion with bulk file reads.
- Alert when authentication-sensitive processes access unrelated document or key material.
- Preserve audit telemetry for administrative access to secure-communications systems.
- Correlate credential collection with subsequent internal movement and new relay behavior.

Mission context matters: a single file-read event may be ordinary. Authentication data, secure-communications configuration and removable-media collection occurring within the same intrusion story is not.

The platform targeted information with durable intelligence value

IDENTITY

credentials / admin access

MISSION

documents / archives

CRYPTO

keys / protected comms

TOPOLOGY

systems / roles / trust

12. Per-target customization and anti-forensics

ProjectSauron reduced the value of traditional IOC sharing by tailoring artifacts, infrastructure and metadata to individual victims.

Layer	Customization pattern
Implants	Unique or heavily customized per target.
Filenames	Masqueraded as legitimate software or environment-appropriate components.
Timestamps	Tailored to the victim environment; tooling could copy timestamps from legitimate files.
C2 / infrastructure	Domains and servers intended not to be reused across victim organizations.

The IOC paradox

A hash can be perfect for one infected organization and almost useless for the next. The stronger analytical objects are behavioral relationships: unusual password filters, raw removable-media access, internal relay roles, memory-only module loading, novel DNS patterns and administrative workflows that change without valid provenance.

Timestamp tailoring and cleanup

Public analysis documented tooling that could copy timestamps from legitimate files and tailor PE / filesystem metadata. Other components could remove files after collection or task completion.

WEAK EVIDENCE ALONE

File creation time, PE timestamp and "old-looking" metadata can all be manipulated.

STRONGER CHRONOLOGY

MFT/USN records, EDR first-seen time, backup history, peer-system comparison, signature/catalog state and deployment logs provide harder-to-fake context.

Original hypothesis: environment-perfect timestamps become suspicious when content provenance is absent. An old-looking file missing from golden images, manifests and peer systems deserves more scrutiny, not less.



13. How do you hunt malware designed to erase patterns?

The answer is to stop treating the indicator as the whole detection model. Both major investigations began with behavior that contradicted the expected role of trusted systems.

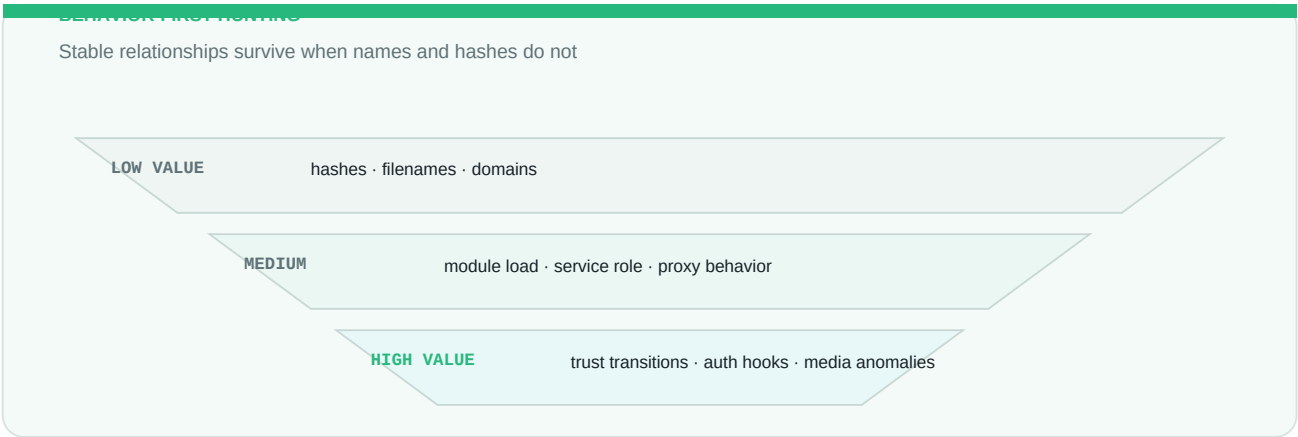
Weak standalone signal	Stronger correlated question
One suspicious hash	Why is an unapproved module loaded into LSASS on a domain controller?
One rare domain	Why does a high-value server query a new domain with recurring high-entropy labels?
One USB insertion	Does the physical media layout contain addressable sectors beyond the mounted partition?
One unsigned DLL	Was it deployed through an administrator script that changed outside normal approval?
No file on disk	Did the process allocate executable memory or receive a transient module immediately after network tasking?

Hunting principle: when the adversary attacks the indicator layer, shift detection toward invariants: privileged trust positions, role changes, memory execution, protocol misuse, removable-media geometry and unexpected data flow.

Telemetry priority

- Domain-controller module inventory
 - Registry change auditing
 - EDR memory / module telemetry
 - MFT and USN chronology
- DNS, proxy and flow logs
 - Removable-media raw-device metadata
 - Deployment-script version control
 - Centralized admin-system audit logs

Investigation mindset: reconstruct relationships between trusted components rather than waiting for the same malicious filename to appear twice.

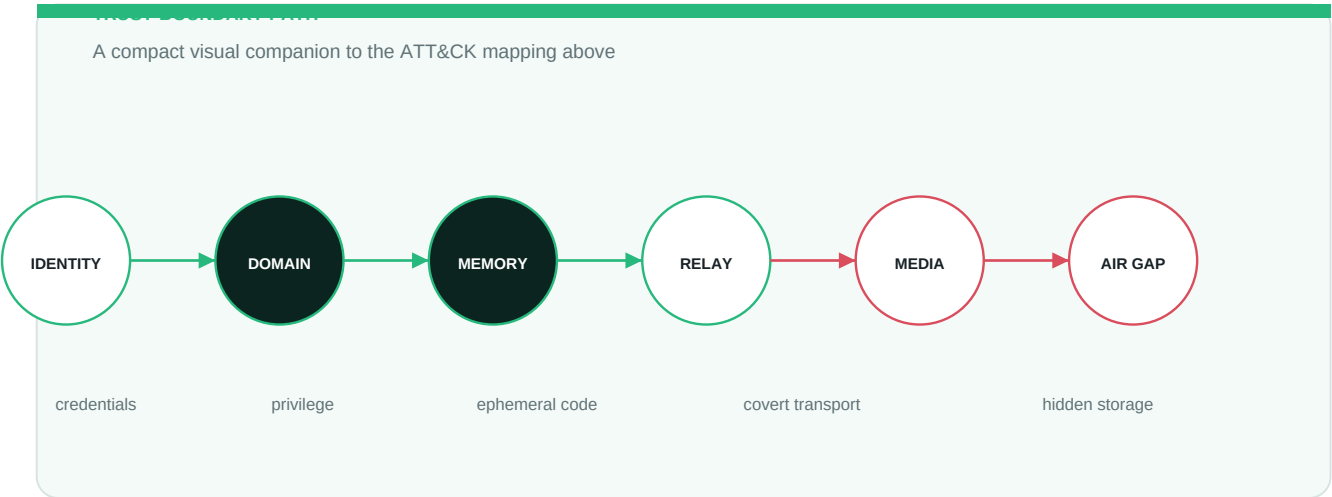


14. Techniques and trust-boundary reconstruction

Technique	ProjectSauron / Remsec use
T1556.002 - Password Filter DLL	Authentication-process modification on domain controllers to capture credentials.
T1052.001 - Exfiltration over USB	Hidden removable-media storage used to bridge isolated networks.
T1071.004 - DNS	Metadata exfiltration and operation-status signaling.
T1090.001 - Internal Proxy	Internet-connected internal servers could relay traffic for isolated systems.
T1059.011 - Lua	Modified embedded Lua engine orchestrated task execution.
T1025 - Data from Removable Media	Dedicated collection from inserted USB devices.
T1070.004 - File Deletion	Components could remove files after collection or tasking.
T1036.005 - Match Legitimate Name / Location	Malicious components mimicked legitimate software names.
T1564.005 - Hidden File System	Custom hidden storage / VFS mechanisms reduced normal OS visibility.

Trust-boundary reconstruction

Boundary	Actor leverage	Defensive choke point
Authentication	Password filter gains plaintext credential visibility.	Strict allowlist and change control for LSASS-loaded extensions.
Admin deployment	Legitimate scripts become code-delivery infrastructure.	Versioned scripts, signed content and peer approval.
Disk -> memory	Task-specific modules execute transiently.	Executable-memory and module telemetry.
Internal segmentation	Dual-homed servers become relay nodes.	Role-based network baselines and egress controls.
DNS trust	Ubiquitous protocol carries metadata and milestones.	Resolver analytics and process-to-query correlation.
USB device trust	Known media carries hidden physical storage.	Full-device geometry validation and controlled transfer stations.



15. Detection hypotheses and defensive blueprint

Historical IOCs are useful for retrospective hunting, but ProjectSauron's per-target customization makes control-oriented hypotheses more durable.

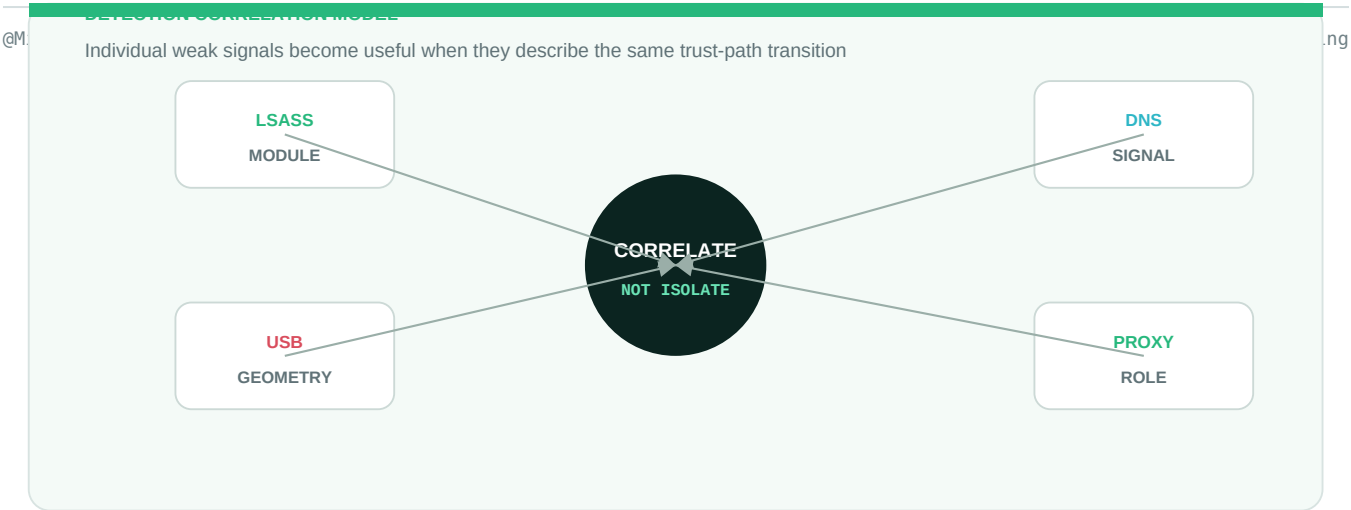
Hypothesis	Telemetry	Validation
Unauthorized auth extension	Registry, LSASS module inventory, code-signing metadata.	Compare against approved domain-controller baseline and change tickets.
Memory-only tasking	EDR executable memory, network-to-process correlation, module load events.	Look for transient executable code with no durable provenance.
Deployment-script abuse	Git/config history, script hashes, admin audit logs.	Alert on unreviewed commands, raw IPs and new downloaders.
Internal relay role change	NetFlow, proxy, firewall and host network telemetry.	Detect servers bridging segments or initiating novel egress.
Low-volume DNS signaling	Resolver logs, query entropy, first-seen domains.	Correlate with privileged configuration changes.
Hidden removable-media storage	Disk capacity, partition table and raw-sector acquisition.	Compare visible partition end with physical storage size.
Timestamp cloning	MFT, USN, EDR first-seen and software inventory.	Trust event chronology over mutable file metadata.

Control blueprint: harden the trust positions first. Authentication-process integrity, governed software deployment, segmented egress, centralized DNS, memory-capable EDR and controlled removable-media transfer deliver more durable coverage than expanding a static hash blacklist.

Correlation beats isolated alerts

A rare DNS lookup, a USB insertion or a script edit may be benign alone. A privileged configuration change followed by unusual DNS, transient memory execution and a new internal relay role is an investigation-worthy sequence.

Design goal: preserve enough cross-layer telemetry that the operation can be reconstructed even when every individual binary, filename or domain is unique.



16. Safe emulation, myths and primary sources

Safe Red Team / research emulation

Authorized labs can validate the same detection surfaces without recreating the espionage platform.

- Register a benign test authentication extension in an isolated Windows lab and verify detection / approval workflows.
- Use a harmless in-memory plugin that writes a marker instead of collecting credentials.
- Modify a lab-only deployment script to launch a benign test binary and verify configuration-drift alerting.
- Generate synthetic DNS labels containing non-sensitive test strings at low volume.
- Create a removable-disk image with unused sectors after the visible partition and verify raw-device inspection.
- Simulate an internal relay using approved test traffic and validate segmentation analytics.

Do not emulate: plaintext credential theft, covert exfiltration from third parties, unauthorized removable-media manipulation, persistence on production domain controllers or real-world air-gap intrusion.

Common myths

Myth	Correction
"ProjectSauron was a USB worm."	USB transfer was one specialized capability inside a broader modular espionage platform.
"The air-gap technique proves a zero-day."	Public analysis did not identify a zero-day in the examined material.
"No reusable IOC means no detection."	Behavioral and trust-boundary telemetry remain viable even when artifacts are unique.
"Vendor victim counts can be added together."	They represent different visibility and collection scopes.

Primary evidence trail

Kaspersky GReAT — ProjectSauron FAQ: <https://securelist.com/faq-the-projectsauron-apt/75533/>

Kaspersky GReAT — The ProjectSauron APT Technical Analysis: https://securelist.com/files/2016/07/The-ProjectSauron-APT_Technical_Analysis_KL.pdf

Broadcom / Symantec — Strider cyberespionage group turns eye of Sauron on targets: <https://community.broadcom.com/symantecenterprise/viewdocument/strider-cyberespionage-group-turns>

MITRE ATT&CK — Strider G0041: <https://attack.mitre.org/groups/G0041/>

MITRE ATT&CK — Remsec S0125: <https://attack.mitre.org/software/S0125/>

Final lesson: ProjectSauron did not win by hiding one perfect binary. It reduced patterns across identities, artifacts, network infrastructure, timestamps and physical media, forcing defenders to reconstruct the operation from invariant behavior.